

Slide 1

Fuego Bank Risk Assessment

Taki Swanson: CSC 312

Slide 2

What is Risk?

Likelihood of an event occurring

Outcome may be positive or negative

Used for smarter decision-making

Risks may impact operations, finances, or customers

Slide 3

Purpose of a Risk Assessment

What are we trying to achieve?

Identify and prioritize threats tied to assets

Reduce risks in the bank's current state

Understanding threats guides risk-reduction strategy

Slide 4

What might affect the business/customers?

Assets:

Hardware

brick & mortar location

software

data

financials

reputation

Slide 5

Continued...

Threats:
malfunction
tampering
damage
Weak passwords
theft
malware
vulnerabilities
crashes
system errors
insider misuse
phishing

Slide 6

Risk Prioritization

Which assets and threats are most important?
Consider likelihood of occurrence
Evaluate potential business impact
Risks include both threats AND opportunities

Slide 7

Risk Assessment Matrix

Slide 8

Threat Impact

Slide 9

What should we do about it?

Implement a security policy
Protect confidentiality, integrity, and availability (CIA)
Administrative, technical, and physical safeguards
Applies to all employees, contractors, and vendors
Covers hardware, software, networks, and customer data

Slide 10

Governance & Responsibilities

CISO oversees security and compliance
Employees must follow policy and report incidents
IT manages access, patching, backups, and monitoring
System owners approve access and system changes

Slide 11

Access Control & Acceptable Use

Multi-factor authentication (MFA) required
Least privilege; quarterly account reviews
No unauthorized software or personal devices
No password sharing; systems for business use only

Slide 12

Data Protection & System Security

Data classification: Confidential, Internal, Public
Encryption at rest and in transit
Endpoint protection, IDS/IPS, secure configurations
Monthly patching and continuous monitoring

Slide 13

SDLC & Change Management

Security integrated into all SDLC phases
Code reviews and vulnerability testing required
Documented approvals for all changes
Emergency changes reviewed after implementation

Slide 14

Physical Security Controls

Locked server rooms with restricted access
CCTV monitoring and visitor logs
Environmental controls: HVAC, fire suppression
Secure disposal of hardware and documents

Slide 15

Incident Response & Business Continuity

NIST process: Identify → Contain → Eradicate → Recover → Report
BCP/DRP with annual testing
Encrypted backups stored offsite
Compliance: GLBA, SOX, PCI-DSS, NIST SP 800-53